



Incident report analysis

Instructions

As you continue through this course, you may use this template to record your findings after completing an activity or to take notes on what you've learned about a specific tool or concept. You can also use this chart as a way to practice applying the NIST framework to different situations you encounter.

Summary	The organization experienced a denial-of-service (DoS) attack in the form of an ICMP flood (ping flood). A malicious actor sent a massive volume of ICMP packets through a misconfigured firewall, which lacked adequate rules to limit or filter this type of traffic.
Identify	Improper firewall configuration, which allowed unrestricted entry of ICMP packets from unverified external sources. Affected systems: the entire internal network was impacted — network services stopped responding, and legitimate traffic from internal users could not access any network resources. Source of the attack: malicious external traffic directed at the internet-facing firewall interface. Estimated impact: approximately two hours of downtime across all network services, disrupting operations until containment by the incident management team. Type of attack: DoS via ICMP packet flood (also known as a "ping flood"), exploiting the absence of rate limiting on the firewall.
Protect	To reduce the likelihood of recurrence, the following controls and processes should be implemented or updated: Review and correct the configuration of all firewalls on the network, ensuring explicit

	rate-limiting rules exist for inbound ICMP traffic (already implemented as an initial response, but should be formalized into policy). Implement source IP address verification (anti-spoofing) at all network edge points, not only on the main firewall. Establish a "deny by default" policy for non-essential traffic types, allowing only what is explicitly required for operations. Conduct periodic audits (e.g., quarterly) of firewall configurations, access rules, and user privileges to identify misconfigurations before they can be exploited. Train the security and IT team on secure firewall configuration and on the risks of denial-of-service attacks. Document and standardize the configuration process for new network devices, including a mandatory security checklist.
Detect	To improve the speed and efficiency of detecting future incidents: Deploy and maintain network monitoring software to identify abnormal traffic patterns (for example, sudden spikes in ICMP packets). Configure the IDS/IPS system to generate automatic alerts when ICMP traffic exceeds defined normal thresholds (traffic baseline). Establish a baseline for normal network traffic, so significant deviations can be quickly identified as potential threats. Continuously monitor firewall and authentication logs to identify unauthorized access attempts or traffic from untrusted IPs. Regularly review user accounts (authorized and unauthorized) to detect unusual activity, such as login attempts outside normal hours or from unexpected locations. Define a periodic review process (daily/weekly) for alerts generated by the IDS/IPS to ensure warning signs are not overlooked.

Respond	Containment: upon detecting an abnormal increase in ICMP traffic, the team should immediately apply blocking/rate-limiting rules on the firewall and isolate the affected network segments, keeping critical services operational whenever possible. Neutralization: use the firewall rules already configured (ICMP rate limiting, source IP verification) and the IDS/IPS system to filter malicious traffic, stopping the attack source without affecting legitimate users. Analysis: collect and preserve firewall logs, IDS/IPS records, traffic captures (PCAP), and network monitoring records to identify the origin, method, and scope of the attack. Communication: notify internal stakeholders (management, IT teams) about the incident status, actions taken, and impact on services. Continuous improvement: after each incident, review the response plan and update procedures based on lessons learned.
Recover	o restore normal operations after an incident: Information to recover immediately: status of critical and non-critical services, integrity of network configuration data (firewall rules, IDS/IPS), and logs from the incident period for post-event analysis. Recovery processes: gradually restore non-critical services that were taken offline during containment, verifying the integrity of each system before reconnecting it to the network. Validation: confirm that the new firewall rules, source IP verification, and IDS/IPS configurations are working correctly before considering the incident fully resolved. Documentation: record a complete timeline of the incident, the actions taken, and the outcomes, for use in future training and audits. Post-incident communication: inform stakeholders about the resolution, the improvements implemented, and the preventive measures adopted to reduce the risk of recurrence.

Reflections/Notes: